MOMENTO 1 — FUNDAMENTOS Y SEGURIDAD DE REDES

Sistemas de Comunicación y Seguridad Informática

Semana 4 — Martes 22 de Septiembre de 2026

Tema: Gestión de Identidades y Accesos (IAM) — Mecanismos de autenticación, autorización y filosofía Zero Trust

Docente: Mg. Gabriel Guerrero Arellano

> *"La seguridad moderna ya no se basa en dónde estás ubicado físicamente, sino en quién eres y qué estás autorizado a hacer."*

Conectando el Ecosistema — Semanas 1 a 4

Semana 1 — Criptografía

Algoritmos de Hashing (SHA-256) y Cifrado Asimétrico. En IAM, las contraseñas nunca se guardan en texto plano; se almacenan protegidas mediante **Hashing con Salt**.

Semana 2 — Firewalls / Wireshark

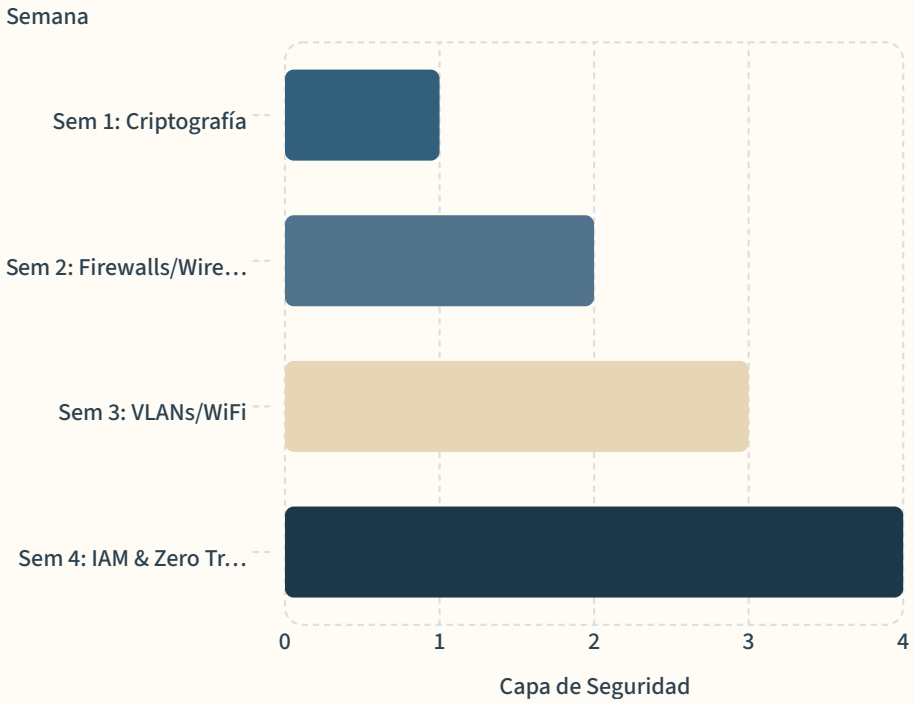
Captura de paquetes y filtrado de tráfico. Si la autenticación no viaja cifrada, las credenciales pueden ser **interceptadas en la red**.

Semana 3 — VLANs / WiFi

Segmentación de departamentos por VLAN. ¿Cómo sabe la red a qué VLAN asignar automáticamente a un usuario? **Respuesta: Servidor IAM/RADIUS.**

Semana 4 — IAM & Zero Trust

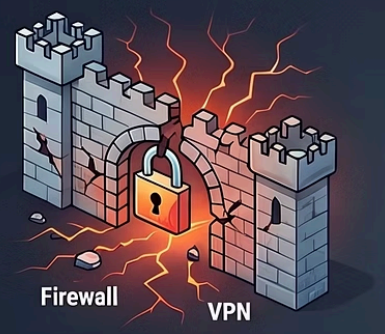
Control de Identidad centralizado. **Cierre del Momento 1.**



Progresión lógica y acumulativa de los temas de seguridad — de menor a mayor abstracción.

IAM de Zero Trust: La Identidad como el Nuevo Perímetro de Seguridad

EL FIN DEL PERÍMETRO TRADICIONAL Y LOS NUEVOS RETOS



PERÍMETRO OBSOLETO

Los firewalls y VPN son insuficientes; la identidad es el control en entornos hibridos.



NUEVO PERÍMETRO: IDENTIDAD

PRINCIPIOS Y HOJA DE RUTA DE IMPLEMENTACIÓN

Los Pilares de Zero Trust IAM



VERIFICACIÓN CONTINUA

Verificación continua en cada acceso.

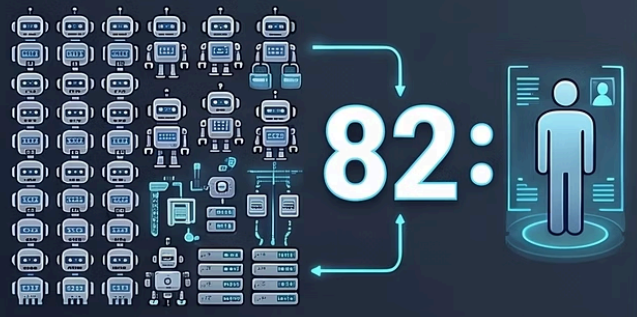
PRIVILEGIO MÍNIMO

Acceso solo a lo esencial.

AUTENTICACIÓN FUERTE (MFA)

MFA en cada acceso.





82:1 - El Auge de Identidades No Humanas

Las cuentas de máquinas y servicios superan drásticamente a las identidades humanas.

El Peligro de las "Islas de Identidad"



ISLAS DE IDENTIDAD

Repositorios fragmentados en múltiples nubes generan puntos ciegos y una gobernanza deficiente.

HOJA DE RUTA DE EJECUCIÓN PROGRESIVA



DÍA 30: CIMIENTOS

- MFA en todo
- Identificar silos
- Bloquear cuentas de administrador

DÍA 90: COHERENCIA

- Consolidar identidades
- Gestionar dispositivos
- Creer cuentas de emergencia

LARGO PLAZO: MADUREZ

- Autenticación sin contraseña
- Monitoreo de comportamiento
- Políticas como código

Gemini Notebook

¿Qué es IAM? — Identity & Access Management

Definición: Marco de políticas, procesos y tecnologías que garantiza que los usuarios correctos tengan el acceso adecuado a los recursos tecnológicos apropiados.

El Modelo AAA

Autenticación (Authentication)

¿Quién eres?

Verificación de la identidad declarada mediante credenciales presentadas por el usuario o sistema.

Autorización (Authorization)

¿Qué tienes permitido hacer?

Definición de privilegios y permisos sobre recursos específicos una vez verificada la identidad.

Auditoría / Contabilidad (Accounting)

¿Qué hiciste y cuándo?

Registro de eventos, logs de acceso y trazabilidad completa de las acciones realizadas.

Mecanismos de Autenticación y MFA

Factores de Autenticación

1

Algo que sabes

Contraseña, PIN, preguntas secretas.

2

Algo que tienes

Token físico, aplicación Authenticator, tarjeta inteligente, teléfono móvil.

3

Algo que eres

Biometría — huella dactilar, reconocimiento facial, escáner de iris.

Autenticación Multi-Factor (MFA)

Exige al menos **2 factores de categorías distintas** para conceder el acceso.

Elimina el punto único de falla de la contraseña como único mecanismo de defensa.

Protocolos Centralizados de Red

RADIUS

Remote Authentication Dial-In User Service: Estándar abierto para centralizar la autenticación de usuarios en redes.

TACACS+

Protocolo propietario de Cisco para administración de infraestructura de red.

Modelos de Autorización — RBAC vs. ABAC

RBAC — Role-Based Access Control

> Los permisos se asignan a **roles** (Administrador, Soporte, Docente, Estudiante), no a personas directamente.

> Facilita la administración escalable en organizaciones grandes.

> Ejemplo: El rol "Docente" puede publicar contenido; el rol "Estudiante" solo puede leerlo.

ABAC — Attribute-Based Access Control

> Evaluación dinámica basada en atributos combinados: **rol del usuario + hora del día + ubicación geográfica + estado de seguridad del dispositivo.**

> Mayor granularidad y flexibilidad que RBAC para entornos complejos.

Principio del Menor Privilegio: Cada usuario y sistema debe tener únicamente los permisos mínimos indispensables para ejecutar sus tareas. Reduce drásticamente la superficie de ataque.

Criterio	RBAC	ABAC
Base de decisión	Rol asignado	Múltiples atributos dinámicos
Granularidad	Media	Alta
Complejidad de gestión	Baja	Alta
Caso de uso ideal	Organizaciones grandes y estables	Entornos dinámicos y distribuidos

La Filosofía Zero Trust — "Confianza Cero"

Modelo Tradicional (Obsoleto)

Seguridad Perimetral: "Todo lo que está dentro de la red corporativa es de confianza; lo de afuera es peligroso."

Falla ante amenazas internas, credenciales comprometidas y trabajo remoto.

"Nunca confiar, siempre verificar implícitamente."

Pilares Fundamentales

1 Verificar Explícitamente

Autenticar y autorizar siempre basándose en todos los puntos de datos disponibles: identidad, ubicación, dispositivo, servicio, carga de trabajo.

2 Usar Acceso de Menor Privilegio

Limitar el acceso con **Just-In-Time (JIT)** y **Just-Enough-Access (JEA)** para reducir la exposición de datos y la posibilidad de movimiento lateral.

3 Asumir la Brecha (Assume Breach)

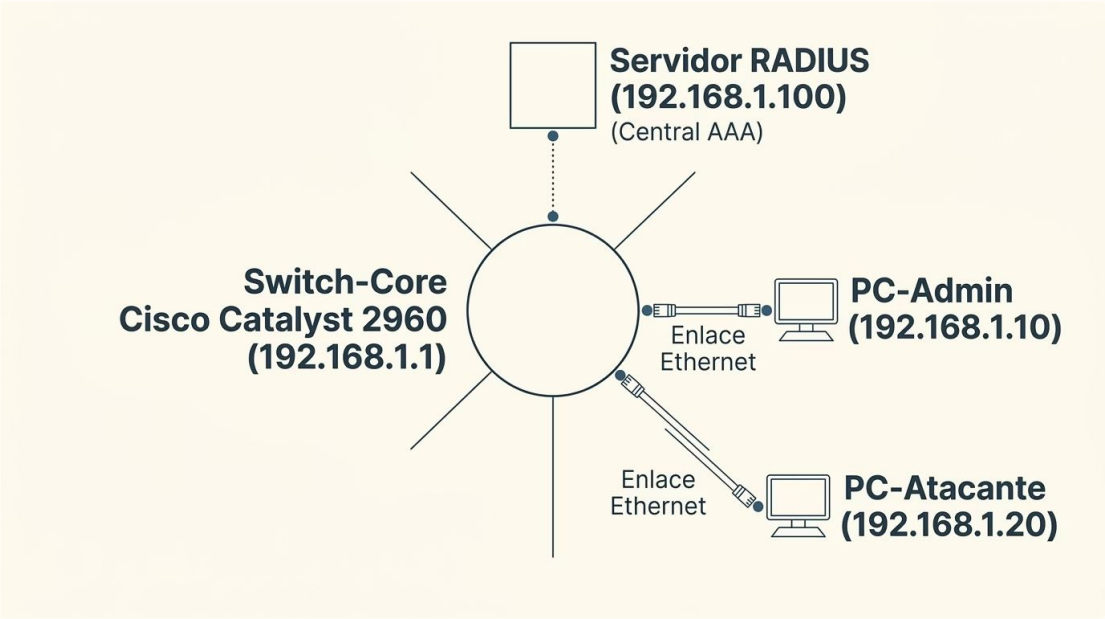
Minimizar el dominio de colisión cifrando todas las comunicaciones internas y monitoreando el comportamiento en tiempo real.

☕ *Receso pedagógico de 10 minutos*

Herramientas del Laboratorio

SOFTWARE: CISCO PACKET TRACER

Objetivo Práctico: Configurar un escenario de infraestructura donde un Servidor AAA (RADIUS) centralice las identidades de la organización. Un Switch solicitará al servidor RADIUS la validación de credenciales antes de otorgar acceso a la consola de administración.



Componentes de la Topología

Servidor AAA/RADIUS — Server-RADIUS

IP: `192.168.1.100` / MASK: `255.255.255.0`

Switch Administrable — Switch-Core

Cisco Catalyst 2960 | IP VLAN 1: `192.168.1.1` / MASK: `255.255.255.0`

PC-Admin

IP: `192.168.1.10` / MASK: `255.255.255.0`

PC-Atacante

IP: `192.168.1.20` / MASK: `255.255.255.0`

Laboratorio — Fase 0: Verificación de Requisitos (Setup)

01

Abrir Cisco Packet Tracer

Iniciar la aplicación y crear un nuevo proyecto en blanco.

02

Desplegar los nodos en el lienzo

Agregar y renombrar cada dispositivo con su configuración IP correspondiente.

03

Conectar todos los equipos al Switch

Usar **cables directos Ethernet** para conectar Server-RADIUS, PC-Admin y PC-Atacante al Switch-Core.

04

Presionar Fast Forward Time (Alt + N)

Asegurar que todos los enlaces estén en **verde** antes de continuar.

Configuración de Nodos

Dispositivo	Nombre	IP
Server	**Server-RADIUS**	192.168.1.100
Switch 2960	**Switch-Core**	192.168.1.1
PC 0	**PC-Admin**	192.168.1.10
PC 1	**PC-Atacante**	192.168.1.20

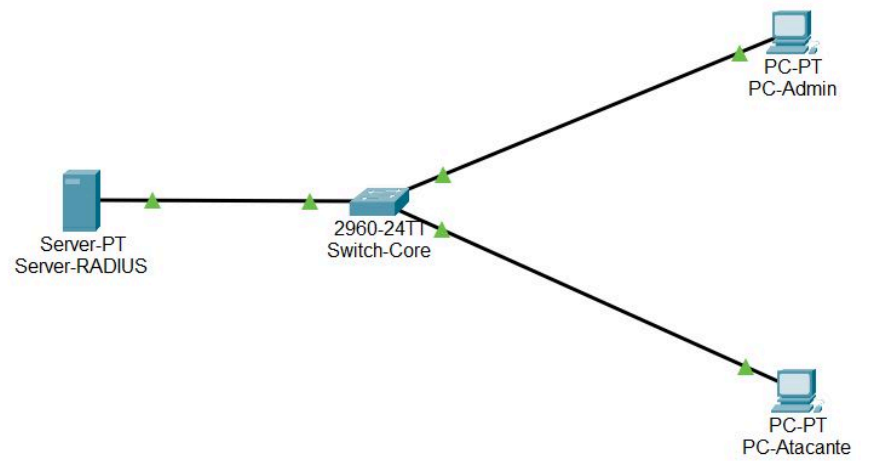
Todos los dispositivos usan MASK: 255.255.255.0

en el switch se debe ejecutar estos comandos:

```
Switch#enable
Switch#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Switch(config)#interface vlan 1
Switch(config-if)#ip address 192.168.1.1 255.255.255.0
Switch(config-if)#no shutdown

Switch(config-if)#
%LINK-5-CHANGED: Interface Vlan1, changed state to up
exit
```

y para probar que tenemos conexión a la vlan del switch desde el PC-Admin **ping 192.168.1.100,** la topología general debe quedar asi en este punto o presionar Alt+ N



Laboratorio — Fase 1: Configuración del Servidor IAM / RADIUS

01

Activar el Servicio AAA

Clic en **Server-RADIUS** → Pestaña **Services** → Seleccionar **AAA** → Estado: **ON**

02

Sección Network Configuratión Setup

Agregar el Switch como cliente RADIUS:

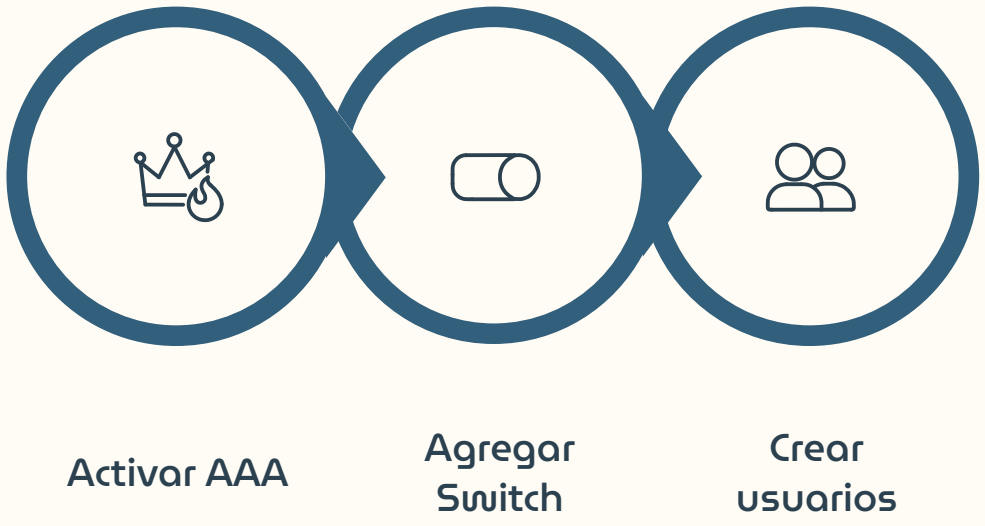
- Client Name: **Switch-Core**
- Client IP: `192.168.1.1`
- Secret: `ClaveSecretA2026!`
- Server Type: **RADIUS** → Clic en **Add**

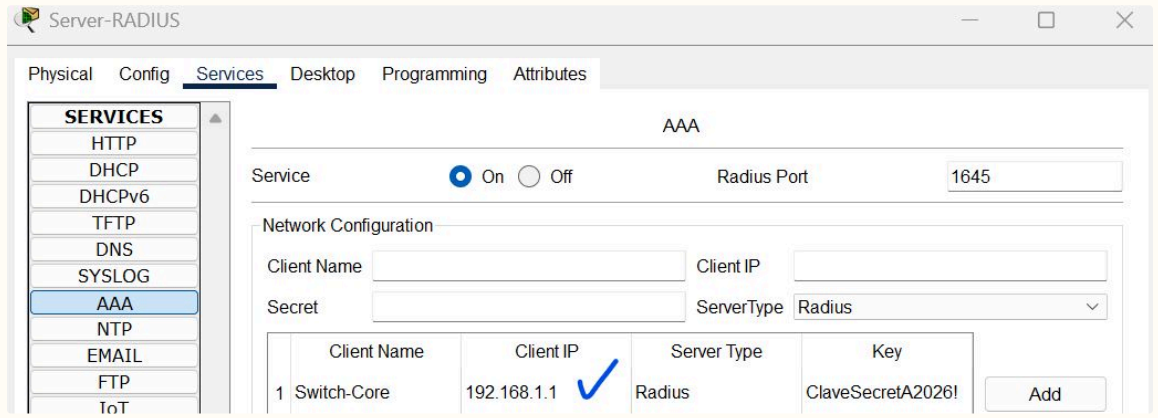
03

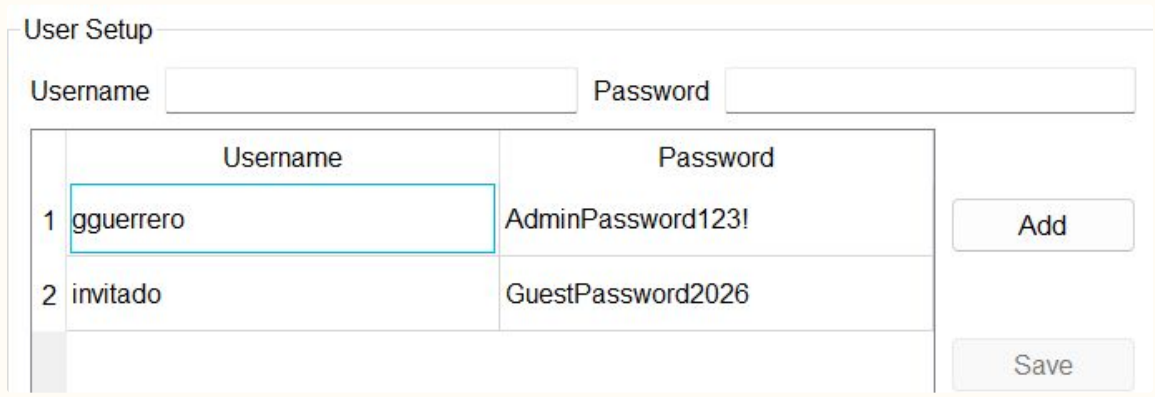
Sección User Setup — Base de Identidades y Roles

Crear los usuarios en la base de datos del servidor:

- Usuario Admin: **gguerrero** / `AdminPassword123!` → Add
- Usuario Invitado: **invitado** / `GuestPassword2026` → Add







Laboratorio — Fase 2: Configuración del Switch para AAA (CLI)

Entrar al **Switch-Core** → Pestaña **CLI** e ingresar la siguiente sintaxis completa:

```
enable
configure terminal

! 1. Configurar la dirección IP del Switch en la VLAN 1:
interface vlan 1
 ip address 192.168.1.1 255.255.255.0
 no shutdown
exit

! 2. Activar el modelo de seguridad AAA:
aaa new-model

! 3. Apuntar al Servidor RADIUS configurado en la Fase 1:
radius-server host 192.168.1.100 key ClaveSecretA2026!

! 4. Configurar la lista de autenticación por defecto usando RADIUS y respaldo local:
aaa authentication login default group radius local

! 5. Proteger las líneas de acceso remoto VTY (Telnet/SSH) y Consola:
line vty 0 15
 login authentication default
exit
line console 0
 login authentication default
end
```

Laboratorio — Fase 3: Pruebas de Autenticación y Verificación de Identidad

✅ PRUEBA DE IDENTIDAD VÁLIDA (PC-ADMIN)

01

Abrir la terminal

Abrir **Command Prompt** en PC-Admin.

02

Ejecutar Telnet

`telnet 192.168.1.1`

03

Ingresar credenciales válidas

User: **gguerrero**
Password: `AdminPassword123!`

04

Resultado Esperado

`Switch-Core>` — Acceso concedido correctamente a la línea de comandos.

```
C:\>telnet 192.168.1.1
Trying 192.168.1.1 ...Open


User Access Verification

Username: gguerrero
Password:
```

La prueba de usuario válido (`gguerrero`) FUE UN ÉXITO:

- En el segundo intento, al ingresar las credenciales correctas de `gguerrero`, el servidor RADIUS autenticó al usuario y el Switch te dio acceso inmediato a la consola: `Switch>`.
- Como tenías el comando listo en el teclado, escribiste `telnet 192.168.1.1` estando ya dentro del Switch (hiciste un Telnet anidado del Switch hacia sí mismo), lo cual abrió una nueva petición de login.

❌ PRUEBA DE ACCESO NO AUTORIZADO

01

Cerrar sesión y reconectar

Cerrar sesión y volver a ejecutar `telnet 192.168.1.1`

02

Intentar credencial inválida

Usuario: **usuario_falso**
Password: `clave123`

03

Resultado Esperado

`Access denied` — Bloqueo automático por el servidor IAM/RADIUS.

```
Switch>exit

[Connection to 192.168.1.1 closed by foreign host]
C:\>telnet 192.168.1.1
Trying 192.168.1.1 ...Open


User Access Verification

Username: usuario_falso
Password:
% Login invalid
```

La prueba de usuario no autorizado (`usuario_falso`) BLOQUEÓ EL ACCESO:

- Al intentar ingresar con `usuario_falso`, el servidor RADIUS no encontró la identidad en su base de datos y devolvió el mensaje `% Login invalid`. ¡Esto demuestra que la seguridad AAA y el control de identidades están activos!

Laboratorio — Fase 4: Políticas Zero Trust (Autorización de Comandos)

En el servidor RADIUS podemos definir no solo **quién entra** (Autenticación), sino **qué comandos puede ejecutar** (Autorización).

Ejecutar en el CLI del Switch para que el servidor valide el nivel de privilegios (Exec mode):

```
enable
configure terminal
aaa authorization exec default group radius local
end
```

Análisis Técnico

Consulta en Tiempo Real

Si un usuario intenta acceder a la consola, el Switch consulta en **tiempo real** al servidor RADIUS si la identidad **gguerrero** posee el nivel de privilegio necesario para entrar al modo de configuración ejecutiva.

Degradación Automática de Rol

Si no lo tiene, es **degradado automáticamente a un rol restringido.**

Pilares Zero Trust Implementados

Este mecanismo implementa directamente los pilares Zero Trust de **Verificar Explícitamente** y **Menor Privilegio.**

Resumen del Ejercicio Realizado

01

Despliegue de la Infraestructura Centralizada

Se conectaron la PC-Admin, la PC-Atacante y el Server-RADIUS a un único Switch-Core en la VLAN 1 de administración.

02

Servidor IAM como Única Fuente de Verdad (Source of Truth)

En lugar de crear cuentas de usuario locales en el Switch, se configuró el servicio AAA/RADIUS en el servidor, creando la identidad del administrador (`gguerrero`) y una clave secreta compartida (Secret) para la relación de confianza con el Switch.

03

Delegación de Autenticación en el Switch

Mediante el CLI del Switch, activamos `aaa new-model` y enlazamos las líneas de administración remota (VTY - Telnet) al servidor RADIUS. El Switch dejó de evaluar usuarios por su cuenta y pasó a delegarle esa responsabilidad al servidor.

04

Prueba Empírica de Autenticación y Autorización

Intento No Autorizado: Al ingresar credenciales inexistentes (`usuario_falso`), el servidor RADIUS rechazó la solicitud devolviendo `% Login invalid`.
Intento Autorizado: Al usar `gguerrero`, el servidor validó la identidad y el Switch otorgó acceso inmediato a la consola (`Switch>`).

05

Elevación de Privilegios (Zero Trust)

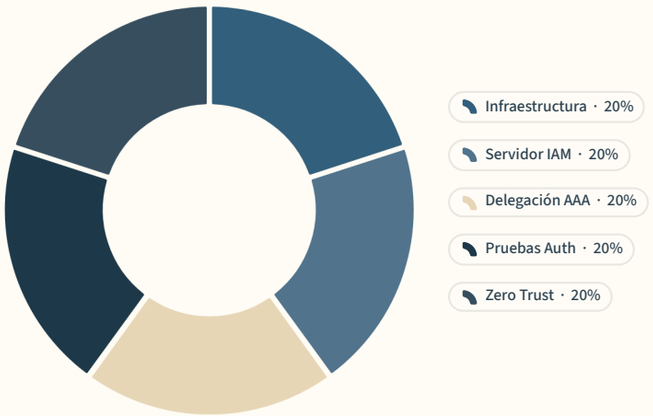
Al intentar ejecutar `configure terminal` desde el modo usuario, el sistema bloqueó el comando, exigiendo escalar explícitamente a modo privilegiado (`enable` / `Switch#`).

Contexto del Ejercicio

Este laboratorio implementó un modelo de **IAM centralizada** aplicando el marco **AAA (Authentication, Authorization, Accounting)** mediante el protocolo **RADIUS** en un entorno simulado de **Cisco Packet Tracer**.

En lugar de gestionar identidades localmente en cada dispositivo, toda la lógica de acceso fue delegada a un servidor central, siguiendo los principios del modelo **Zero Trust**: verificar explícitamente, aplicar menor privilegio y asumir siempre la posibilidad de compromiso.

Fases del Laboratorio



Conclusiones y Lecciones Aprendidas

CONCLUSIONES CLAVE DEL TALLER — PARA LA REFLEXIÓN CON LOS ESTUDIANTES

01

Escalabilidad Organizacional vs. Gestión Local

En una empresa con cientos de switches y routers, crear o borrar usuarios equipo por equipo es inviable y peligroso. La centralización con RADIUS / TACACS+ permite que un administrador cree o revoque un acceso en una sola base de datos central (ej. Active Directory) y el cambio se aplique al instante en toda la infraestructura de red.

02

Implementación Práctica de Zero Trust — 'Nunca confiar, siempre verificar'

Estar físicamente conectado a un puerto del Switch no garantiza acceso a su gestión. La red asume que cualquier dispositivo conectado es potencialmente hostil hasta que demuestre una identidad válida y verificada ante el servidor IAM.

03

Separación Estricta entre Autenticación y Autorización

Autenticación: Demuestra quién eres (ingresar con `gguerrero`). Autorización: Determina qué puedes hacer (bloqueo de `configure terminal` en `Switch>` hasta contar con nivel `enable`). Esto responde directamente al Principio del Menor Privilegio (Least Privilege).

04

Resiliencia y Alta Disponibilidad

La sintaxis `aaa authentication login default group radius local` enseña una buena práctica fundamental en ciberseguridad: si el servidor RADIUS pierde conexión o cae, el dispositivo mantiene un mecanismo de contingencia (fallback) a la base de datos local para evitar que los ingenieros queden bloqueados fuera de la red.

Estas lecciones conectan directamente la teoría IAM con la realidad operativa de las redes empresariales modernas.

Pilares Aplicados en el Taller

Escalabilidad Centralizada

Zero Trust Aplicado

Auth vs. Autorización

Resiliencia AAA

Cierre del Docente

> "Hoy hemos cerrado el Momento 1 aprendiendo a controlar la Identidad y los Accesos (IAM) con filosofías Zero Trust. Con esto completamos las bases de redes y criptografía. **¡A partir de la Semana 5 iniciaremos el Momento 2, donde entraremos al apasionante mundo de la Explotación de Vulnerabilidades y Pentesting con Metasploit!**"

— Mg. Gabriel Guerrero Arellano

Semana 1

Criptografía y Hashing

Semana 2

Firewalls y Wireshark

Semana 3

VLANs y WiFi

Semana 4 ✓

IAM y Zero Trust

Momento 1 completado. Próxima sesión: Semana 5 — Explotación de Vulnerabilidades y Pentesting con Metasploit.